

Severance CTF Write-up

Author: @elesquina

Challenge Overview

The Severance challenge presented a corporate espionage scenario where the player assumed the role of a disgruntled employee at Atlas Digital who had been denied their performance bonus. The challenge provided access to two corporate systems through legitimate credentials and required exploiting various security vulnerabilities to fraudulently approve and process a payment to the player's account. The objective centered on understanding corporate workflows, gathering intelligence through information disclosure vulnerabilities, and executing a multi-stage attack chain involving credential compromise and business logic exploitation.

Initial Access Credentials:

Username: ybenali

Password: WorkFlow2024!

System Architecture Discovery

The challenge environment consisted of two primary applications representing common corporate infrastructure components. AtlasMail served as the internal email communication system, providing functionality for composing messages, managing inbox and sent folders, and facilitating inter-employee communication. WorkHub functioned as the financial management platform, handling invoice creation, approval tracking, and transaction processing. These systems operated with distinct but interconnected workflows where email communications triggered financial actions based on specific approval patterns.

Initial exploration of both systems revealed the standard invoice approval workflow followed by Atlas Digital. The process required three distinct stages: invoice creation by any authorized employee, executive approval from the Chief Executive Officer through email communication to the finance department, and final payment processing by the finance team upon receipt of verified approval. Understanding this workflow proved essential for constructing the attack chain, as each stage represented both a necessary step and a potential vulnerability point.

Information Gathering Phase

Systematic exploration of the email system revealed valuable intelligence embedded within routine corporate communications. An email from Karim Tazi, the IT Operations administrator,

contained technical documentation regarding system integrations. This message casually mentioned the existence of an employee data API endpoint located at `/api/employee/` accessible through standard authentication headers. This disclosure represented the first critical vulnerability, as API endpoints intended for internal integration purposes were exposed to any authenticated user regardless of their authorization level or legitimate business need.

Testing the discovered endpoint revealed its full capabilities and the extent of information disclosure:

```
curl https://ideh-severance-2.chals.io/api/employees \
-H "Cookie: session=<session_token>"
```

The endpoint returned a complete directory of all company employees including their names, departments, and unique identifiers. This represented a significant privacy violation and provided attackers with a comprehensive organizational map. More critically, individual employee profiles could be retrieved through the pattern `/api/employee/{id}`, exposing substantially more sensitive information for each user.

Target Profile Analysis

Retrieving individual employee profiles through the API revealed extensive personal and security-relevant information. The Chief Executive Officer's profile proved particularly valuable for the attack objective:

```
curl https://ideh-severance-2.chals.io/api/employee/2 \
-H "Cookie: session=<session_token>"

{
  "id": 2,
  "name": "Fatima Alami",
  "email": "f.alami@atlasdigital.ma",
  "username": "falami",
  "security_question": "Pet name + founding year",
  "start_date": "2019-01-15",
  "office": "CASA-Executive-01"
}
```

The exposed security question "Pet name + founding year" provided a clear target for password recovery or account compromise. This information disclosure violated fundamental security principles by revealing the exact authentication factors required for account access. Similar exposure existed for the Finance Manager profile, though the CEO account proved more valuable for the attack chain given their role in the approval workflow.

OSINT and Credential Derivation

The challenge incorporated publicly available information throughout the application that served dual purposes as legitimate corporate content and intelligence sources for attackers. The news section contained several articles describing company achievements and employee activities. Two articles proved particularly relevant for answering the exposed security question.

The first article titled "Atlas Digital Team Conquers the Marrakech Marathon" featured a quote from CEO Fatima Alami discussing her participation in the event. Within this quote, she mentioned her beloved cat Zina waiting at home, describing how the pet had become something of an unofficial company mascot. This casual personal disclosure provided the first component of the security question answer: the pet name "Zina".

The second article celebrated the company's five-year anniversary milestone, titled "Celebrating 5 Years of Innovation in Morocco". The content explicitly stated the company's founding year as 2019, marking their journey from a small Casablanca startup to a regional technology leader. This provided the second component needed for the security question.

Combining these publicly available data points yielded the complete security answer: **Zina2019**. The construction pattern followed a predictable format where users concatenate memorable information without additional complexity, special characters, or obfuscation. This represented a common weakness where security questions based on publicly discoverable information provide minimal actual security while creating a false sense of account protection.

Compromised CEO Credentials:

Username: falami

Password: Zina2019

Attack Execution

With the CEO credentials compromised, the attack proceeded through the established workflow stages, exploiting each system's trust assumptions. The first stage involved creating a fraudulent invoice using the original authenticated session. The invoice documented a fictitious performance bonus payment, crafted to appear legitimate within normal business operations:

```
curl -X POST https://ideh-severance-2.chals.io/work/invoices/create \
-H "Cookie: session=<ybenali_session>" \
-d "vendor=Youssef Benali - Performance Bonus" \
-d "description=Q4 2024 Outstanding Performance" \
-d "amount=100000" \
-d "bank_account=MA64 0111 1234 5678 9012 3456 78"
```

The system accepted the invoice submission and assigned a unique identifier following the pattern INV-2024-XXXXXXXX-0001. This invoice entered a pending state awaiting executive approval according to the established workflow. The system implemented no validation regarding the legitimacy of self-submitted invoices or the appropriateness of employees creating payment requests for themselves, representing a significant business logic vulnerability.

The second stage required authenticating as the CEO to send the approval communication. Establishing a new session with the compromised credentials provided full access to the CEO's email account and administrative privileges:

```
curl -X POST https://ideh-severance-2.chals.io/login \
-d "username=falami" \
-d "password=Zina2019"
```

Using this authenticated session, the attack proceeded to compose and send an approval email to the Finance department. The email followed standard corporate communication patterns, including proper formatting, professional language, and all necessary invoice details. The content explicitly authorized payment processing while appearing entirely legitimate from both technical and business perspectives:

```
POST /mail/compose
To: s.idrissi@atlasdigital.ma
Subject: APPROVED: Invoice INV-2024-XXXXXXXX-0001

Salma,

Please authorize the following:

Vendor: Youssef Benali - Performance Bonus
Invoice: INV-2024-XXXXXXXX-0001
Amount: $100,000.00

Fatima Alami
CEO, Atlas Digital
```

The critical vulnerability exploited at this stage involved the system's complete trust in email sender authentication. The application verified that the email originated from an authenticated CEO session but failed to implement additional security controls such as digital signatures, multi-factor approval requirements, or out-of-band verification mechanisms. The system's sole validation checked whether the logged-in user possessed CEO privileges, a condition trivially satisfied with compromised credentials.

Flag Retrieval

Following successful approval email transmission, the automated workflow processed the payment according to established business rules. The finance system received the approval email, validated the sender's CEO status through session information, matched the invoice identifier to the pending request, and executed the payment transaction. Accessing the transactions page revealed the completed fraudulent payment along with the challenge flag, confirming successful exploitation of the entire attack chain.

Vulnerability Analysis

The challenge incorporated multiple interconnected vulnerabilities, each contributing to the overall compromise. The information disclosure through the employee API represented the initial breach, exposing sensitive data that should have been restricted based on role-based access controls. The endpoint failed to implement authorization checks beyond basic authentication, allowing any authenticated user to enumerate all employees and retrieve detailed personal information including security questions.

The security question mechanism provided minimal actual security while creating a dangerous false sense of protection. Security questions fundamentally suffer from the contradiction of requiring answers that are both memorable to legitimate users and difficult for attackers to discover. When the answer derives from publicly available information, this mechanism becomes purely ceremonial. The specific question "Pet name + founding year" proved particularly weak as both components appeared in public company communications accessible without authentication.

The absence of multi-factor authentication for high-privilege accounts represented a critical missing control. The CEO account, which possessed authority to approve significant financial transactions, relied solely on password authentication without requiring additional verification factors. Modern security frameworks consistently recommend MFA for any account with elevated privileges, administrative access, or financial authorization capabilities. The compromised password alone granted complete account access without triggering any additional security challenges.

The business logic vulnerability in the approval workflow proved most significant from an operational security perspective. The system implemented a seemingly reasonable control requiring CEO approval for invoices but failed to verify approval authenticity beyond checking session credentials. Email-based approval systems should incorporate cryptographic signatures, unique approval tokens, or dedicated secure channels rather than trusting standard email communications. The ability to send approval emails from a compromised account completely bypassed the intended control.

Additional weaknesses included the lack of anomaly detection for unusual invoice patterns, such as employees creating self-payment requests or approvals occurring immediately after invoice creation. The system implemented no separation of duties preventing the same account from both creating and approving transactions. Rate limiting appeared absent on both authentication

attempts and API requests, facilitating both credential attacks and information gathering activities.

Attack Chain Summary

The complete exploitation followed a logical progression through multiple system weaknesses. Initial reconnaissance through email exploration discovered API endpoint documentation. Information disclosure through insufficiently protected APIs revealed organizational structure and individual employee details including security questions. Open source intelligence gathering from public company communications provided security question answers. Credential compromise through predictable password patterns derived from security questions granted CEO account access. Business logic exploitation through email-based approval mechanisms authorized fraudulent payments. Each stage built upon previous compromises, demonstrating how multiple moderate vulnerabilities combine to enable significant impact.

Key Vulnerabilities Exploited

Information Disclosure via API

Weak Security Questions

No Multi-Factor Authentication

Business Logic Bypass

Insufficient Authorization Controls

Email Trust Without Verification

Missing Anomaly Detection

Lack of Separation of Duties